CVEs más relevantes de la semana

Del 24/10/2026 al 31/10/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-116111

Descripción: A vulnerability was determined in 2K Games Civilization V 1.0.3.144. Impacted is the function loadstring of the component Lua Sandbox. Executing a manipulation can lead to type confusion. The attack may be performed from remote. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 6.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:L

Tipo: CWE-843

Tecnología: No especificado

Publicado el: 2026-10-26

CVE-2026-116231

Descripción: A security flaw has been discovered in Oray Pugongying X5 Pro 7.6.1. The impacted element is an unknown function of the component Ser2net. Performing a manipulation of the argument regmsg results in crlf injection. It is possible to initiate the attack remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early about this disclosure but did ...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-10-26

CVE-2026-116234

Descripción: A vulnerability was detected in Oray Pugongying X5 Pro 7.6.1. Affected is an unknown function of the file /etc/ipsec.conf of the component IPsec Policy Handler. The manipulation of the argument secproto results in crlf injection. The attack can be launched remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-10-26

CVE-2026-116214

Descripción: MacCMS v10 before 2026.1000.4054 contains an authentication bypass vulnerability that allows unauthenticated attackers to reset any member's password because check_msg() never compares msg_to. Attackers can request a recovery code to their own mailbox via user/findpass_msg, then submit it to user/findpass_reset with the victim's email or phone to take over the account.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-640

Tecnología: No especificado

Publicado el: 2026-10-26

CVE-2026-116485

Descripción: danmu_api before 1.21.7 contains an authentication bypass vulnerability that allows unauthenticated attackers to modify server environment configuration when the default TOKEN is used and ADMIN_TOKEN is unset. Attackers can send POST requests to /api/env/set, /api/env/add, or /api/env/del to set ADMIN_TOKEN, lock out operators, redirect OTHER_SERVER or PROXY_URL for SSRF, and trigger redeployment.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-26

CVE-2026-112346

Descripción: OpenHands Software Agent SDK before 1.52.0 contains an unauthenticated remote code execution vulnerability where the DockerWorkspace and Apptainer workspace launchers bind the sandbox agent server to all network interfaces (0.0.0.0) with an empty session_api_keys list, disabling authentication by default. Attackers who can reach the published container port can send unauthenticated HTTP and Web...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1327

Tecnología: No especificado

Publicado el: 2026-10-26

CVE-2026-116370

Descripción: A security flaw has been discovered in 2K Games Sid Meier's Civilization VI 1.0.12.68. The affected element is the function loadstring of the component Lua sandbox. Performing a manipulation results in type confusion. The attack may be initiated remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early about this disclosure.

CVSS: 6.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:L

Tipo: CWE-843

Tecnología: No especificado

Publicado el: 2026-10-26

CVE-2026-115915

Descripción: vLLM is an inference and serving engine for large language models. Prior to 0.32.0, ImageMediaIO passes attacker-controlled image bytes to Pillow through Image.open(BytesIO(data)) without restricting decoder selection, and the MIME label does not constrain the selected format. Image-capable request paths through parse_image() and fetch_image() can therefore dispatch an EPS payload to host compo...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-10-26

CVE-2026-116506

Descripción: A vulnerability was determined in TOTOLINK A950RG 4.1.2cu.5268_B20221104. Affected is the function apmib_set of the file firewall.so. This manipulation causes command injection. The attack may be initiated remotely. The exploit has been publicly disclosed and may be utilized.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-10-26

CVE-2026-117532

Descripción: REDAXO core from 5.3.0 before 5.21.4 contains an authentication bypass vulnerability in the structure/history plugin that allows unauthenticated attackers to forge temporary login tokens. Attackers can force the session-tied secret into a predictable state and forge tokens for accounts like admin, gaining backend access and code execution outside live mode.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-104350

Descripción: Adobe Campaign Classic (ACC) is affected by a reflected Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this vulnerability to inject malicious scripts into a web page, potentially gaining elevated access or control over the victim's account or session. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact with ...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-104351

Descripción: Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-104353

Descripción: Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-105779

Descripción: Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in a Security feature bypass. A low-privileged attacker could leverage this vulnerability to bypass security measures and gain unauthorized read and limited write access. Exploitation of this issue does not require user interaction. ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-105780

Descripción: Adobe Campaign Classic (ACC) is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-105781

Descripción: Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary SQL commands, potentially gaining elevated access or control over the victim's account or session. Expl...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-118333

Descripción: Missing authorization in Video in Google Chrome prior to 156.0.8078.73 allowed a remote attacker to bypass web origin policy via a crafted HTML page. (Chromium security severity: High)

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-118337

Descripción: Improper access control in Forms in Google Chrome prior to 156.0.8078.73 allowed a remote attacker to bypass web origin policy via a crafted HTML page. (Chromium security severity: High)

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-103406

Descripción: An Improper Neutralization of Special Elements used in an OS Command vulnerability in the AutomatedProvisioner in Juniper Networks Session Smart Conductor allows a remote attacker to execute arbitrary commands as root via a specially crafted salt minion ID.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-28

CVE-2026-103409

Descripción: A Missing authentication for critical function vulnerability in Juniper Networks Session Smart Router allows an unauthenticated network-based attacker to obtain administrative privileges by passing crafted URL parameters to an insecure endpoint running as root.

Note that this vulnerability can only be exploited prior to the device being onboarded to Mist/Conductor. The issue can no longer be e...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-28

CVE-2026-117574

Descripción: A flaw was found in ai-gateway-payload-processing. An authenticated remote attacker can exploit this vulnerability by submitting a request specifying another tenant's model identifier in the request body or header. Because the service does not verify authorization before retrieving credentials from the shared store, it injects the target tenant's application programming interface (API) keys int...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-10-28

CVE-2026-104317

Descripción: IBM Langflow OSS 1.0.0 through 1.12.3 could allow a remote attacker who could reach the message broker to execute arbitrary code on the system due to the deserialization of untrusted data.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-10-29

CVE-2026-18894

Descripción: IBM Langflow OSS 1.0.0 through 1.12.4 could allow a remote attacker to trigger pre-existing stored Python component code in a public workflow, executing it under the flow owner's runtime context within the server process. This bypasses the intended trust boundary where public execution paths are restricted to server-trusted component code.

CVSS: 6.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-10-29

CVE-2026-119597

Descripción: OpenDeepWiki through 2.0.6 contains a hard-coded JWT signing key vulnerability that allows unauthenticated attackers to forge administrator tokens using the publicly known Jwt:SecretKey in appsettings.json. Attackers can mint HS256 bearer tokens with an Admin role claim to access /api/admin endpoints and control users, roles, repositories, settings, and API keys.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-321

Tecnología: No especificado

Publicado el: 2026-10-30

CVE-2026-119660

Descripción: MuseBot before 2.0.0 contains an authentication bypass vulnerability that allows unauthenticated attackers to forge admin sessions by using the hard-coded default session_key 'muse_bot_session_key'. Attackers can sign a MuseBot-session cookie carrying a user_id to gain full administrative access, reading password hashes, chat records, and bot configuration, and stopping bots.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1394

Tecnología: No especificado

Publicado el: 2026-10-30

CVE-2026-119706

Descripción: InternLM LMDeploy 0.9.0 through 0.18.0 contains an unauthenticated remote code execution vulnerability that allows remote attackers to run OS commands by sending pickled data to the /update_weights endpoint. Attackers can submit a base64-encoded crafted pickle in serialized_named_tensors, which ForkingPickler.loads deserializes without validation, executing commands as the api_server process.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-10-30

CVE-2026-109220

Descripción: The PDF Invoice for WooCommerce + Drag and Drop Template Builder plugin for WordPress is vulnerable to PHP Object Injection in all versions up to, and including, 7.1.1 via the 'customer_note' parameter parameter. This is due to insufficient sanitization of the customer_note checkout field, which is inlined verbatim into invoice HTML, entity-decoded back into a live tag by simplehtmldom, reassem...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-10-31

CVE-2026-116557

Descripción: The WP Booking System - Booking Calendar plugin for WordPress is vulnerable to unauthorized modification of data due to a missing capability check on the wpbs_action_ajax_calendar_remove_note() function in versions up to, and including, 2.1.0.5 This makes it possible for authenticated attackers, with Subscriber-level access and above, to delete arbitrary calendar notes belonging to any calendar.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-10-31

CVE-2026-89270

Descripción: The Popup Builder – Create highly converting, mobile friendly marketing popups. plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 4.4.5 This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to trash all published popups on the site with a single unauthen...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-10-31

CVE-2026-116512

Descripción: The Project Manager – AI Powered Project Management, Task Management, Kanban Board & Time Tracker plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 4.1.1 via the 'id' parameter parameter. This is due to unsanitized 'id' parameter value concatenated directly into the pipe-delimited validation rule string, which is then split and each token invoked ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-10-31

CVE-2026-119096

Descripción: The Uncanny Toolkit for LearnDash plugin for WordPress is vulnerable to Authentication Bypass in versions up to, and including, 3.8.2 via the `email` parameter of the `uo_login_action()` function. This is due to a parser-differential flaw in which the plugin's account-verification gate resolves the submitted `email` value using the raw, unsanitized string passed to `get_user_by()`, while the su...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-10-31

CVE-2026-103882

Descripción: The Acadlix LMS – AI Quiz Maker, Online Exam & Course Plugin for WordPress plugin for WordPress is vulnerable to arbitrary file deletion due to insufficient file path validation in the post_delete_assessment_file_by_id function in all versions up to, and including, 1.1.9. This makes it possible for authenticated attackers, with subscriber-level access and above, to delete arbitrary files on the...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-10-31

CVE-2026-118235

Descripción: The SimpleForm – Form Maker to Chat Apps with Quiz, Poll and Multi Lead Notifications plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 3.10.2 via the handle_upload function. This is due to missing server-side file key allowlist and pre-sanitization extension derivation that allows a trailing-dot filename to bypass all extension and MIME validatio...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-10-31

Resumen del Reporte

CVEs analizados: 33

Promedio CVSS: 9.21

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat

